

МЕТОДИКА ОПРЕДЕЛЕНИЯ ЦЕННОСТИ ЗАЩИЩАЕМЫХ АКТИВОВ ДЛЯ АУДИТА ОБЕСПЕЧЕНИЯ ИНФОРМАЦИОННОЙ БЕЗОПАСНОСТИ КОММЕРЧЕСКОЙ ОРГАНИЗАЦИИ

О.М. Голембиовская, К.Е. Шинаков, Е.В. Кондрашова, А.П. Жолнеров

В статье рассматривается методика, связанная с определением ценности активов для аудита обеспечения информационной безопасности коммерческой организации. Помимо этого, предложен подход для прогнозирования нанесения возможного ущерба рассматриваемым активам. Предлагаемую методику целесообразно применять службам безопасности предприятия с целью выявления недостатков системы защиты и выполнению различных мер по нейтрализации или минимизации вероятности реализации возможных угроз. Определение ценности активов организации является важным этапом аудита. Основными активами коммерческой организации с точки зрения обеспечения информационной безопасности являются: информационная система, сервер, компьютеры и иное оборудование для работы сотрудников, внутренние базы данных. Процедура определения ценности активов описана отдельно для каждого из них.

Ключевые слова: коммерческая организация, актив, ущерб, информационная безопасность, защита информации.

В современном мире информационной безопасности (ИБ) уделяется все большее внимание. На это повлияло серьёзное развитие информационных технологий, полная информатизация многих сфер в обществе. Атакующие технологии развиваются быстрее защитных, поэтому даже государственные базы данных находятся в зоне риска. В данный момент ситуацию также осложняет массовый переход к работе в дистанционном формате, который значительно облегчает процесс получения данных злоумышленниками [1-10].

Главным инструментом для контроля уровня защиты информационных активов организации является аудит ИБ. Благодаря аудиту информационной безопасности можно получить объективную оценку ситуации с обеспечением ИБ, а при выполнении полученных рекомендаций можно сделать защиту информационных ресурсов более эффективной и полностью обезопасить инфраструктуру. Для российских бизнес-реалий понятие аудита информационной безопасности является сравнительно новым, однако сегодня он

широко применяется компаниями, которые осознают значение защищенности данных.

К задачам аудита ИБ можно отнести:

- Подтверждение соответствия требованиям (стандартов, регуляторов и пр.);
- Выявление уязвимостей ИТ-инфраструктуры;
- Выявление уязвимостей в процессах (в том числе в процессе самого обеспечения ИБ);
- Получение рекомендаций по улучшению/изменению системы обеспечения информационной безопасности.

Особенно важно проведение аудита ИБ для коммерческих организаций.

Коммерческими организациями признаются юридические лица, основной целью деятельности которых является получение прибыли. Коммерческие организации могут создаваться в форме товариществ и обществ, производственных кооперативов, государственных и муниципальных предприятий.

Риск информационной безопасности – возможность того, что рассматриваемая угроза сможет воспользоваться уязвимостью

актива или группы активов и тем самым нанесет ущерб организации. [11]

Угрозы информационной в России и мире преимущественно экономического «происхождения». Вследствие реализации угрозы возможны следующие последствия:

- Утечка конфиденциальных данных в организации
- Внешние атаки на информационные системы компании
- Действия неблагонадежных сотрудников (человеческий фактор)
- Доступ к потенциально опасным объектам во внешней сети
- Получение информации при помощи технических средств
- Вредоносное ПО (трояны, бэкдоры, блокировщики, шифраторы и т. д.)
- Использование нелегальных программных решений, зачастую содержащие не декларируемые возможности

Согласно статистике, опубликованной Positive Technologies за 2020 год, доля атак на коммерческие организации составила 60% от общего числа. Активный перевод сотрудников на удаленную работу и вывод внутренних сервисов компаний на сетевой периметр, обусловленные пандемией COVID-19, повлияли на ландшафт киберугроз во всем мире. Лишь немногие компании, которые и так практиковали работу в удаленном режиме, были готовы справиться со всеми сложностями в обеспечении безопасности, остальные столкнулись с нехваткой времени на продумывание и реализацию всех необходимых мер защиты.

Злоумышленники стали более интенсивно искать уязвимости в сервисах на периметрах компаний, в том числе в решениях, используемых для организации удаленной работы. Активно эксплуатировались бреши в Pulse Secure VPN, Citrix ADC и Citrix Gateway, в межсетевом экране Cisco ASA. Операторы программ-вымогателей, в частности Netwalker, Clor и REvil, пользовались уязвимыми сервисами для распространения своего ВПО. В целом доля хакинга среди методов атак на организации выросла на 10 процентных

пунктов по сравнению с прошлым годом и составила 24%. [10]

Помимо этого, одно из популярных течений в области угроз – рост рынков по продаже доступов к серверам компаний. На сегодняшний день, даже если хакеры не смогли продвинуться в атаке дальше найденной уязвимости и получения доступа к серверу, они могут легко продать этот доступ. При этом пострадать может не только ИТ-инфраструктура компании, но и ее лицо в интернете — сайт, что влечет за собой не только финансовые, но и репутационные риски.

Определение ценности активов организации является важным этапом аудита ИБ и предотвращения возможных угроз. Именно эта процедура позволяет детально рассмотреть не только механизмы реализации угроз для конкретных активов, но и оценить возможные финансовые риски. После того, как будет спрогнозирован возможный финансовый ущерб, появляется возможность подсчитать все необходимые затраты на построение современной системы защиты и в цифрах обосновать ее необходимость.

Активы - это ресурсы, контролируемые компанией, от которых ожидается экономическая выгода в будущем. Материальные активы характеризуют имущественные ценности предприятия, имеющие материальную вещественную форму, как правило именно они подвергаются атакам. [9]

Основными активами коммерческой организации с точки зрения обеспечения информационной безопасности являются: информационная система, сервер, компьютеры и иное оборудование для работы сотрудников, внутренние базы данных. Процедура определения ценности активов описана отдельно для каждого из них.

Актив: компьютер (АРМ работника)

Относительно данного актива может произойти угроза разрушения (пожар, вышел из строя). В таком случае работник не сможет выполнять свои служебные функции определенный период времени, однако, работодатель вынужден будет платить заработную плату. На основании данных

рассуждений можно сделать вывод о следующем ущербе:

1. Заработная плата – 31266 руб. (данные Брянскстата [1]).

2. Стоимость среднестатистического ПК – 40000 руб. [2]

Итого: 71 266 рублей.

Актив: сервер

Относительно данного актива может произойти угроза разрушения (выход из строя, перегрев), а также угроза нарушения доступности (сбои работы, постоянные перезагрузки, отключения вследствие перегревов). В случае выхода из строя сервера, необходимы затраты на покупку нового, помимо этого возможен простой организации и выплата заработной платы работникам. В случае нарушения доступности необходимы затраты на ремонт оборудования. На основании данных рассуждений можно сделать вывод о следующем ущербе:

1. Заработная плата – 31266 руб. [1]

2. Покупка нового сервера – 50000 руб. [3]

3. Ремонт сервера – 8000 руб. [4]

Итого: 91 266 рублей.

Актив: стол

Относительно данного актива может произойти угроза разрушения (поломка), в этом случае работник не сможет полноценно выполнять свои обязанности минимум один день. Необходимые затраты – покупка нового стола, выплата заработной платы работнику за один день. На основании данных рассуждений можно сделать вывод о следующем ущербе:

1. Заработная плата за день с учетом 5-дневной рабочей недели и данных Брянскстата о заработной плате [1] – 1563 руб.

2. Стоимость стола – 3 000 руб. [5]

Итого: 4 563 рубля

Актив: стул

Относительно данного актива также может произойти угроза разрушения (поломка), работник не сможет полноценно выполнять свои обязанности минимум один день. Необходимые затраты – покупка нового стула, выплата заработной платы работнику за один день. На основании данных

рассуждений можно сделать вывод о следующем ущербе:

1. Заработная плата за день с учетом 5-дневной рабочей недели и данных Брянскстата о заработной плате [1] – 1563 руб.

2. Стоимость стула – 2 000 руб. [5]

Итого: 3 563 рубля

Актив: база данных информационной системы

Относительно данного актива может произойти угроза нарушения конфиденциальности, целостности, доступности информации (действия злоумышленников, компьютерные вирусы и атаки, сбои). В случае разглашения информации (нарушения конфиденциальности) возможны иски от работников и клиентов организации. В случае нарушения целостности информации для восстановления данных ИС необходимо привлекать программистов. При удалении данных необходимо привлекать инженеров и программистов. Во всех трех случаях возможен простой организации и выплата заработной платы работникам. На основании данных рассуждений можно сделать вывод о следующем ущербе:

1. Заработная плата – 31266 руб. [1]

2. В среднем финансовая компенсация по делам о разглашении информации составляет от 10 до 20 тысяч рублей [6]

3. Работа программиста – 2600 руб./час [7]

4. Работа инженера – 2000 руб./час [7]

Итого: 55 866 рублей

Актив: система отопления

Относительно данного актива может произойти угроза разрушения (выход из строя). В этом случае работники не смогут выполнять полноценно свои трудовые функции в холодное время года как минимум в течении суток, в период работы аварийных служб. На основании данных рассуждений можно сделать вывод о следующем ущербе:

1. Заработная плата за день с учетом 5-дневной рабочей недели и данных Брянскстата о заработной плате [1] – 1563 руб.

Итого: 1563 рубля

Актив: система кондиционирования

Относительно данного актива может произойти угроза разрушения (выход из рассуждений можно сделать вывод о следующем ущербе:

1. Ремонт системы – 2000 руб. [8]
2. Покупка нового сервера – 50000 руб. [4]
3. Ремонт сервера – 8000 руб. [4]

Итого: 58 000 рублей

Таким образом расчет оценки ценности имеет следующий вид:

$Y_a = Y_{kp} + Y_s + Y_{st} + Y_{bd} + Y_{so} + Y_{sk}$, (1)
 где Y_a – итоговый ущерб активу, Y_{kp} – ущерб относительно актива «компьютер работника», Y_s – ущерб относительно актива «сервер», Y_{st} – ущерб относительно актива «стул/стол», Y_{bd} – ущерб относительно актива «база данных информационной системы», Y_{so} – ущерб относительно актива «система отопления», Y_{sk} – ущерб относительно актива «система кондиционирования».

Если какой-либо из параметров не актуален для организации, ввиду отсутствия актива, то он исключается из формулы или приравнивается к нулю.

Для удобства прогнозирования нанесения возможного ущерба активам, предлагается осуществлять ее с помощью анкет для каждого конкретного актива, на каждый вопрос можно ответить только «Да» или «Нет».

Актив: компьютер (АРМ работника)

1. Имущество вашей компании застраховано?
2. Проверяете ли вы раз в год с помощью тестирования исправность проводки в кабинетах ваших работников?
3. Имеется ли у вас резервный ПК на случай выхода из строя ПК работника?
4. Располагаете ли вы возможностью оперативного приобретения ПК стоимостью 40000 рублей?
5. Имеются ли средства резервного копирования?

Актив: сервер

1. Имущество вашей компании застраховано?

строю). В этом случае может произойти перегрев и выход из строя серверного оборудования. На основании данных

2. Проверяете ли вы раз в год с помощью тестирования исправность проводки в кабинетах ваших работников?

3. Располагаете ли вы возможностью оперативного ремонта сервера стоимостью 8000 рублей?

4. Располагаете ли вы возможностью оперативного приобретения сервера стоимостью 50000 рублей?

5. Имеются ли средства резервного копирования?

6. Имеется ли в серверной система кондиционирования?

7. Имеются ли в организации источники бесперебойного питания?

Актив: стол

1. Имеется ли у вас резервный стол на случай выхода из строя мебели работника?

2. Располагаете ли вы возможностью оперативного приобретения стола стоимостью 3000 рублей?

Актив: стул

1. Имеется ли у вас резервный стул на случай выхода из строя мебели работника?

2. Располагаете ли вы возможностью оперативного приобретения стула стоимостью 2000 рублей?

Актив: база данных информационной системы

1. Имеются ли средства резервного копирования?

2. Имеются ли средства обнаружения вторжений?

3. Установлено ли антивирусное ПО?

4. Располагаете ли вы возможностью оплатить срочную работу программиста, стоимостью 2600 рублей?

5. Располагаете ли вы возможностью оплатить срочную работу инженера, стоимостью 2000 рублей?

6. Проводятся ли инструктажи/иная работа с персоналом по предотвращению угрозы атаки со стороны внутреннего нарушителя?

Актив: система отопления

1. Имеете ли вы возможность отапливать помещение в течении суток, в случае отключения центральной системы

отопления? (радиаторами, тепловыми пушками)

2. Имеете ли вы возможность перевести сотрудников на удаленную работу до устранения неполадок?

Актив: система кондиционирования

1. Имущество вашей компании застраховано?

2. Проверяете ли вы раз в год с помощью тестирования исправность проводки в кабинетах ваших работников?

3. Располагаете ли вы возможностью оперативного ремонта сервера стоимостью 8000 рублей?

4. Располагаете ли вы возможностью оперативного приобретения сервера стоимостью 50000 рублей?

5. Располагаете ли вы возможностью оперативного ремонта системы стоимостью 2000 рублей?

6. Имеются ли средства резервного копирования?

В случае ответа «Да» на 2 и более вопроса, вероятность причинения ущерба активу очень высокая. Для того чтобы обезопасить активы и максимально снизить вероятность причинения возможного ущерба, необходимо выполнить все требования, заявленные в вопросах анкеты (сделать так, чтобы на каждый вопрос был ответ «Да»).

Представленная методика позволит владельцам коммерческих организаций значительно упростить процедуру проведения аудита информационной безопасности, самостоятельно оценить степень защищенности присутствующих активов, экономически обосновать, а также предпринять эффективные меры для уменьшения вероятности реализации угроз и предотвращения причинения ущерба.

Список литературы

1. Сайт территориального органа Федеральной службы государственной статистики по Брянской области [Электронный ресурс], URL: <https://bryansk.gks.ru/folder/25521> (Дата обращения: 21.06.2021).

2. Топ персональных компьютеров и их ценовые характеристики [Электронный

ресурс] URL: <https://samyiluchshiy.ru/top-15-luchshih-personalnyh-kompyuterov/> (Дата обращения: 17. 06.2021)

3. ВТК Связь: стоимость сервера [Электронный ресурс] URL: https://www.vtk.ru/articles/servers/Server_Price.php (Дата обращения: 17. 06.2021)

4. Прайс-лист на услуги сервисного центра [Электронный ресурс] URL: <https://fcenter.ru/product/service/price#server> (Дата обращения: 17. 06.2021)

5. Prime Wood: офисная мебель [Электронный ресурс] URL: <https://prime-wood.ru/bryansk/kresla-i-stulya> (Дата обращения: 17. 06.2021)

6. Разъяснение ВС РФ о правилах рассмотрения споров по защите персональных данных [Электронный ресурс] URL: <https://rg.ru/2020/11/09/vs-rf-raziasnil-pravila-rassmotreniia-sporov-o-zashchite-personalnyh-dannyh.html> (Дата обращения: 17. 06.2021)

7. Восстановление базы данных, необходимые затраты [Электронный ресурс] URL: <https://online-kassa.ru/kupit/vosstanovlenie-bazy-1s/> (Дата обращения: 17. 06.2021)

8. Атмосфера-профклимат: ремонт кондиционеров [Электронный ресурс] URL: <https://bryansk.atmosferaprofiklimat.ru/services/remont-konditsionerov> (Дата обращения: 17. 06.2021)

9. ГОСТ Р ИСО/МЭК 27005-2010 «Информационная технология. Методы и средства обеспечения безопасности. Менеджмент риска информационной безопасности.», 01.12.2011.

10. Статистика Positive Technologies [Электронный ресурс] URL: <https://xakep.ru/2021/04/28/pt-2020-report/>

11. Галатенко, В. А. Основы информационной безопасности [Электронный ресурс] / В. А. Галатенко. — Электрон. текстовые данные. — М.: Интернет-Университет Информационных Технологий (ИНТУИТ), 2016. — 266 с. — 978-5-94774-821-5. — Режим доступа: <http://www.iprbookshop.ru/52209.html> (Дата обращения: 25.06.2021).

Брянский государственный технический университет
Bryansk State Technical University

Поступила в редакцию 30.06.2021

Информация об авторах

Голембиовская Оксана Михайловна – канд. техн. наук, доцент кафедры «Системы информационной безопасности», Брянский государственный технический университет, bryansk-tu@yandex.ru

Шинаков Кирилл Евгеньевич – канд. техн. наук, доцент кафедры «Системы информационной безопасности», Брянский государственный технический университет», sib@tu-yandex.ru

Кондрашова Екатерина Владимировна – студент кафедры «Системы информационной безопасности», Брянский государственный технический университет», kondrashova_katerina@bk.ru

Жолнеров Алексей Павлович - магистрант кафедры «Системы информационной безопасности», Брянский государственный технический университет», gap@tu-bryansk.ru

**METHODOLOGY FOR DETERMINING THE VALUE OF PROTECTED ASSETS
FOR THE AUDIT OF PROVIDING THE INFORMATION SECURITY
OF A COMMERCIAL ORGANIZATION**

O.M. Golembiovskaya, K.E. Shinakov, E.V. Kondrashova, A.P. Zholnerov

The article discusses the methodology associated with determining the value of assets for auditing information security of a commercial organization. In addition, an approach is proposed to predict the possible damage to the assets under consideration. It is advisable to apply the proposed methodology to the security services of the enterprise in order to identify the shortcomings of the protection system and implement various measures to neutralize or minimize the likelihood of possible threats. Determining the value of an organization's assets is an important stage of the audit. The main assets of a commercial organization from the point of view of ensuring information security are: an information system, a server, computers and other equipment for the work of employees, internal databases. The procedure for determining the value of assets is described separately for each of them.

Keywords: commercial organization, asset, damage, information security, information protection.

Submitted 30.06.2021

Information about the authors

Golembiovskaya Oksana M. – Cand. Sc. (Technical), Associate Professor of the Department of information security systems, Bryansk state technical University, bryansk-tu@yandex.ru

Shinakov Kirill E. – Cand. Sc. (Technical), Associate Professor of the Department of Information Security Systems, Bryansk State Technical University, sib@tu-yandex.ru

Kondrashova Ekaterina V. – student of the Department of information security systems, Bryansk state technical University, kondrashova_katerina@bk.ru

Zholnerov Alexey P. - master's student of the Department of Information Security Systems, Bryansk State Technical University, gap@tu-bryansk.ru